

Third-Party Vendor Security Assessment — Slack

A self-directed GRC project designing a vendor security questionnaire and applying it to a real, major SaaS provider (Slack) using only publicly available security documentation — the core skill behind third-party/vendor risk management in real GRC programs.

Project Summary

This project evaluates **Slack** (Slack Technologies, a Salesforce company) as a vendor under consideration for adoption as an organization's internal communication and collaboration platform. Unlike the fictional-company projects in this portfolio, this assessment is grounded entirely in real, citable evidence — Slack's public Trust Center, Security Practices page, Compliance page, and GDPR commitment page. The project walks through the full vendor assessment lifecycle:

1. **Questionnaire design** — building a 28-question security questionnaire across five domains (Governance, Access Control, Data Protection, Incident Response & Logging, Compliance), phrased in realistic procurement/security-review language rather than textbook control language
2. **Evidence-based scoring** — scoring each question Yes (2) / Partial (1) / No (0) strictly against what Slack's public documentation actually states, with every score backed by a specific cited source
3. **Vendor Scorecard** — synthesizing the 28 scored answers into a section-by-section breakdown, a visual chart, strengths/weaknesses, and an overall risk rating against a pre-defined risk scale
4. **Vendor Assessment Report** — a one-page executive summary including a before/after analysis of Slack's security posture across two real, publicly disclosed security incidents (2015 and 2022), plus a recommendation with specific follow-up items for procurement

Deliverables

File	Description
Slack_Vendor_Assessment.xlsx / .pdf	Full 28-question questionnaire with evidence notes, plus the Vendor Scorecard (section scores, chart, strengths/weaknesses, risk rating scale)
Slack_Vendor_Assessment_Report.docx / .pdf	One-page report with before/after incident analysis, assessment summary, and procurement recommendation

What I Did

- Designed a 28-question vendor questionnaire across five standard GRC domains, written in realistic, conversational procurement language rather than copied framework terminology

- Researched Slack’s actual public security documentation (Trust Center, Security Practices, Compliance, and GDPR pages) rather than assuming or guessing at vendor capabilities
- Scored all 28 questions using a Yes=2/Partial=1/No=0 model, citing the specific public claim (or noting its absence) behind every single score
- Built a Vendor Scorecard with section-level scoring, a bar chart visualization, and a synthesized strengths/weaknesses summary
- Defined a risk rating scale (Low/Medium/High/Critical by score percentage) *before* finalizing the overall risk label, so the “Low Risk” conclusion follows a rule rather than a subjective call made after seeing the score
- Researched Slack’s actual incident history (the 2015 password database compromise and the 2022 GitHub token theft) to build a real before/after comparison of the vendor’s security maturity over time
- Wrote a one-page report synthesizing the score, the historical trend, and specific, actionable procurement recommendations

What I Learned

- **A vendor questionnaire only has value if it’s specific enough to fail.** Early drafts of these questions were generic enough that almost anything could count as a “Yes.” Rewriting them in real procurement language (“is that on us to figure out?”) forced sharper, more honest answers — and produced the project’s only “No” score.
- **Public documentation has real, predictable gaps.** Vendors are consistently transparent about what they *do* (certifications, features) and consistently vague about specific operational commitments (breach notification timelines, plan-tier-specific enforcement). Knowing where that gap typically falls is itself a useful pattern for future vendor reviews.
- **A score without a documented evidence trail isn’t defensible.** Citing the exact source claim behind each answer — and being honest when no public claim existed — is what separates a credible assessment from a vendor’s own marketing page restated as a scorecard.
- **Vendor risk isn’t static, and a single incident isn’t the whole story.** Slack’s 2015 and 2022 incidents look similar on the surface (unauthorized access via stolen credentials/tokens), but the *response* — speed of detection, transparency of disclosure, and confirmed blast radius — was meaningfully different. A vendor that has had an incident and demonstrably improved afterward can be a safer bet than a vendor with no incident history and no way to verify how they’d actually respond.
- **Risk thresholds should be set before scoring, not after.** Defining the Low/Medium/High/Critical bands in advance, rather than picking a label that felt right once the 89% appeared, is a small process discipline that meaningfully improves the credibility of the conclusion.

Real-World Application

Third-party/vendor risk assessment is one of the highest-volume, most recurring tasks in real GRC roles, particularly as organizations adopt more SaaS tools:

- **Procurement security review** — most mid-size and large organizations require a documented vendor security assessment before any new SaaS tool is approved for company-wide use, and many GRC analysts review dozens of these per quarter
- **Vendor risk tiering** — the scoring/risk-rating approach used here mirrors how real organizations triage vendors (e.g., low-risk vendors get expedited approval, high-risk vendors require additional contractual protections or executive sign-off)
- **Ongoing vendor monitoring, not just onboarding** — the before/after incident analysis reflects a real and growing GRC practice: continuously monitoring existing vendors for new incidents or certification lapses, rather than treating the initial assessment as permanent
- **Standardized industry tools** — this project's structure (sectioned questionnaire, weighted scoring, evidence citation) mirrors real industry frameworks like the Shared Assessments SIG (Standardized Information Gathering) questionnaire used widely in enterprise vendor risk programs

Conclusion

This project completes a third distinct pillar of GRC analyst work, alongside the compliance-matrix and risk-register projects in this portfolio: rather than assessing an organization's own controls or its internal risk landscape, this project assesses an *external* party using only the evidence that party chooses to make public — the same constraint a real analyst faces when a vendor hasn't yet agreed to a deeper audit or questionnaire response. Grounding the assessment in real evidence, including real incident history, rather than a fictional scenario, reflects how vendor risk decisions are actually made: imperfectly, with incomplete information, but as rigorously and transparently as the available evidence allows. Together, these three projects span the discipline a GRC analyst is expected to bring to almost any organization: conformance to an external standard, internal risk reasoning, and informed judgment about parties outside the organization's direct control.

This assessment is based on Slack's publicly available security documentation as of mid-2026 and is intended as a self-directed portfolio exercise. It does not represent an official or contractual vendor risk determination.

Vendor Assessment Report: Slack

Communication & Collaboration Platform | Prepared by Kevin Liao

Slack was assessed using a 28-question security questionnaire across five domains — Governance, Access Control, Data Protection, Incident Response & Logging, and Compliance — scored against Slack's current public security documentation. Slack scored 50 of 56 possible points (89%), placing it in the Low Risk band under a pre-defined scoring scale (85-100% = Low Risk). To contextualize this score, this report also examines Slack's security posture before and after two publicly disclosed incidents, since a vendor's response to past incidents is often a more reliable signal than a point-in-time score alone.

Before / After: Security Posture Over Time

	Before (2015 Incident)	After (2022 Incident & Today)
What happened	Attackers accessed a database of usernames and hashed passwords and inserted code to capture plaintext passwords as users logged in.	Attackers stole employee tokens and accessed Slack's GitHub repositories; no customer data, codebase, or production systems were touched.
Response speed	Passwords reset for affected users after detection; full scope wasn't confirmed until a follow-up disclosure years later.	Tokens invalidated and breach publicly disclosed within 4 days of discovery (Dec 27 to Dec 31).
Resulting controls	Introduced two-factor authentication as a corrective measure following the incident.	Increased GitHub monitoring/alerting; today's program includes EKM, default encryption, and 9 active certifications.

The contrast is meaningful: in 2015, Slack's posture was largely reactive, and the full scope of the incident wasn't clear until a follow-up disclosure years later. By 2022, Slack demonstrated a materially more mature program — fast containment, public transparency within days, and a clear root-cause finding that customer data was never at risk. The current questionnaire results (89%, Low Risk) reflect a vendor whose program has visibly matured over roughly a decade, not a static claim taken at face value.

Assessment Summary

- Governance: 12/12 (100%) — extensive, independently audited certifications (ISO 27001/17/18/701/42001, SOC 2 Type II, SOC 3) with clear shared-responsibility framing.
- Access Control: 10/12 (83%) — strong SSO, domain claiming, and EMM support; org-wide MFA enforcement and session controls not fully confirmed publicly.
- Data Protection: 11/12 (92%) — encryption at rest/in transit by default, customer-managed keys via EKM, and data residency controls.
- Incident Response & Logging: 7/10 (70%) — solid logging and legal hold support, but no public breach notification timeline commitment.
- Compliance: 10/10 (100%) — HIPAA, FINRA 17a-4, FedRAMP, and GDPR are all explicitly supported.

Recommendation

Slack is recommended for adoption as an internal communication and collaboration platform, including for organizations subject to HIPAA, FINRA, or GDPR obligations, provided the following two items are confirmed directly with Slack's account team prior to contract signature rather than assumed from public documentation:

- Request the specific breach notification timeline commitment from the Data Processing Addendum (DPA), since this was not publicly documented.
- Confirm whether org-wide mandatory MFA enforcement and session/device controls are available on the specific plan tier being purchased.

Usefulness of This Assessment

This exercise reflects a core, recurring GRC analyst responsibility: third-party vendors are frequently the weakest link in an organization's security posture, not because vendors are careless, but because customers often adopt tools based on reputation rather than verified evidence. A structured questionnaire, scored consistently and backed by cited evidence, turns "Slack seems secure" into a defensible, auditable conclusion that can be revisited as the vendor's posture changes. The before/after comparison additionally demonstrates that vendor risk assessment is not a one-time gate at procurement — a vendor's trajectory after an incident is often more informative than whether an incident occurred at all, and that pattern should be re-evaluated periodically rather than assumed to hold indefinitely.

Vendor Security Questionnaire — Slack

Scoring: Yes = 2, Partial = 1, No = 0 | Source: Slack public Trust Center, Security Practices, Compliance, and GDPR pages | Prepared by Kevin Liao

#	Section	Question	Response	Score	Evidence / Source Notes
1.1	Governance	Do you have a formal information security program with documented policies, not just informal practices?	Yes	2	Public security whitepaper and dedicated Trust Center describe a structured, documented security program.
1.2	Governance	What third-party certifications or attestations do you currently hold (e.g., SOC 2, ISO 27001)?	Yes	2	Holds ISO 27001, 27017, 27018, 27701, 42001, SOC 2 Type II, SOC 3, and CSA STAR Registry listing.
1.3	Governance	Can you provide your most recent audit report or certificate upon request during the procurement process?	Yes	2	SOC 3 and several ISO certificates are directly downloadable; SOC 2 report available via account team.
1.4	Governance	Do you clearly define what security responsibilities are ours vs. yours once we're using your platform?	Yes	2	Security Practices page explicitly states protecting customer data is a "joint responsibility."
1.5	Governance	Who owns security at your company — is there a named security leader or team we can escalate to?	Yes	2	References a dedicated security team and escalation path; specific named executive not public, but team/escalation structure is described.
1.6	Governance	Are your security claims independently audited, or are they self-reported?	Yes	2	SOC 2 Type II and ISO certifications are independently audited by accredited third parties, not self-attested.
2.1	Access Control	Can we connect our existing SSO provider so employees log in with their company credentials?	Yes	2	Single sign-on explicitly listed under identity and device management features.
2.2	Access Control	Can we require MFA for everyone on our team, or is it optional per user?	Partial	1	MFA is supported, but public docs don't clearly confirm org-wide mandatory enforcement on all plan tiers.
2.3	Access Control	Can we lock down who's allowed to join our workspace based on email domain, so randoms can't sign up?	Yes	2	Domain claiming explicitly listed as a feature.
2.4	Access Control	Do you support mobile device management so we can wipe company data off a lost phone?	Yes	2	Enterprise mobility management (EMM) support explicitly listed.
2.5	Access Control	Can we set session timeouts or restrict which devices can stay logged in?	Partial	1	Implied via EMM/admin controls, but specific session-timeout configuration isn't directly documented publicly.

Vendor Security Questionnaire — Slack

Scoring: Yes = 2, Partial = 1, No = 0 | Source: Slack public Trust Center, Security Practices, Compliance, and GDPR pages | Prepared by Kevin Liao

#	Section	Question	Response	Score	Evidence / Source Notes
2.6	Access Control	Can we give different admins different levels of access instead of everyone having full control?	Yes	2	Enterprise tier documentation references admin role structures (Org Admin, Workspace Admin, etc.).
3.1	Data Protection	Is our data encrypted while it's sitting in storage, or only while it's moving?	Yes	2	Explicitly stated: customer data encrypted at rest and in transit by default.
3.2	Data Protection	Is data encrypted in transit by default, or do we have to turn that on ourselves?	Yes	2	Explicitly stated: encrypted in transit by default, no customer action required.
3.3	Data Protection	Can we manage our own encryption keys, or is that entirely on your side with no visibility for us?	Yes	2	Slack Enterprise Key Management (EKM) explicitly offers customer control to monitor and revoke key access.
3.4	Data Protection	Can we choose what region our data physically lives in (e.g., staying in the US or EU)?	Yes	2	Data residency explicitly offered, letting organizations choose storage region for encrypted data at rest.
3.5	Data Protection	Do you have built-in tools to stop sensitive data from being shared in a message, or do we need a separate DLP tool?	Yes	2	Native DLP plus support for third-party DLP providers explicitly listed.
3.6	Data Protection	Can we set our own rules for how long data is kept before it's automatically deleted?	Partial	1	Retention settings are customer-configurable, but confirmed only on paid plans, not universally across all tiers.
4.1	Incident Response & Log	Can we see a log of who accessed or changed what, in case we need to investigate something?	Yes	2	Audit logs explicitly listed as a data protection feature.
4.2	Incident Response & Log	Do you actively monitor your own systems for suspicious activity, or is it more reactive?	Yes	2	Whitepaper references system monitoring, logging, and alerting as part of the security program.
4.3	Incident Response & Log	If you get breached, do you have an actual incident response plan, or would we be the ones figuring it out?	Partial	1	An IR program is implied through SOC 2 audit scope, but a specific public-facing IR plan document was not found.
4.4	Incident Response & Log	If our data is involved in a breach on your end, how fast are you contractually required to tell us?	No	0	No specific public notification timeframe (e.g., "within 72 hours") found; likely exists in the DPA but is not publicly documented.

Vendor Security Questionnaire — Slack

Scoring: Yes = 2, Partial = 1, No = 0 | Source: Slack public Trust Center, Security Practices, Compliance, and GDPR pages | Prepared by Kevin Liao

#	Section	Question	Response	Score	Evidence / Source Notes
4.5	Incident Response & Log	If we get sued or subpoenaed and need to pull records for legal reasons, can you support that?	Yes	2	Legal holds and eDiscovery support explicitly listed under information governance.
5.1	Compliance	If we're a healthcare org handling patient data, can your platform be set up to stay HIPAA-compliant?	Yes	2	Explicitly stated: configurable for HIPAA compliance including electronically protected health information (ePHI).
5.2	Compliance	If we have EU users, do you actually help us stay GDPR-compliant, or is that on us to figure out?	Yes	2	Dedicated GDPR commitment page; offers Standard Contractual Clauses for international data transfers.
5.3	Compliance	If we're a financial firm, can this be configured to meet FINRA recordkeeping requirements?	Yes	2	Explicitly stated as FINRA 17a-4 configurable.
5.4	Compliance	If we're a government agency or contractor, are you authorized for that (e.g., FedRAMP)?	Yes	2	FedRAMP Moderate authorized; GovSlack separately authorized at JAB High.
5.5	Compliance	Who else touches our data behind the scenes — do you tell us which subprocessors/vendors you use?	Yes	2	Public Subprocessors page explicitly referenced in compliance documentation.

Vendor Scorecard — Slack

Scoring Model: Yes = 2, Partial = 1, No = 0 | Max Score: 56 | Prepared by Kevin Liao

Section	Points Earned	Max Points	Section %
Governance	12	12	100%
Access Control	10	12	83%
Data Protection	11	12	92%
Incident Response & Logging	7	10	70%
Compliance	10	10	100%
TOTAL	50	56	89%

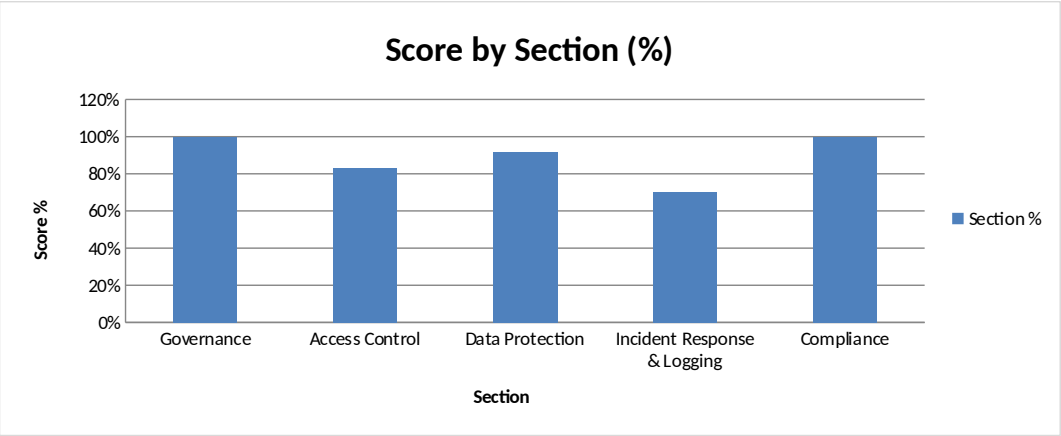
Key Strengths

- Extensive, independently-audited certification portfolio (ISO 27001/17/18/701/42001, SOC 2 Type II, SOC 3, CSA STAR) covering security, privacy, and AI governance.
- Encryption at rest and in transit enabled by default, with customer-managed key control available via Slack Enterprise Key Management (EKM).
- Strong regulatory configurability across multiple industries — HIPAA, FINRA 17a-4, FedRAMP Moderate, and GDPR are all explicitly supported.
- Transparent shared-responsibility framing and public disclosure of subprocessors, supporting informed customer risk decisions.

Key Weaknesses / Gaps

- No publicly documented breach notification timeline commitment to customers — this likely exists in the Data Processing Addendum but is not transparent pre-contract
- Org-wide mandatory MFA enforcement and granular session/device controls are not clearly confirmed as available across all plan tiers from public documentation alone.
- Data retention configurability is confirmed only for paid plans, leaving ambiguity for lower-tier customers.
- Some governance claims (e.g., named security leadership) rely on general program descriptions rather than specific, citable public statements.

Overall Risk Level	LOW RISK
--------------------	----------



Risk Rating Scale (defined before scoring)	
85% - 100%	Low Risk
70% - 84%	Medium Risk
50% - 69%	High Risk
Below 50%	Critical Risk